Incident Response Plan Recommendations Report

> **TO:** Senior Leadership, Sandhaven University
> **FROM:** Cybersecurity Governance and Incident Response Advisory
> **DATE:** September 25, 2026
> **SUBJECT:** Incident Response Plan Recommendations for Sandhaven University Case Study RSN1

A. Recommendations for the Incident Response Plan

1. Organization Identification and Addressable Cybersecurity Incidents

Organization Name: Sandhaven University (SU)

Sandhaven University is a private, nonprofit higher education institution in Los Angeles, California, operating across one main campus and two satellite campuses, with 25,000 students and 2,500 employees. SU manages cloud platforms, student information systems, health clinic records, and sensitive faculty research data.

Based on the university structure and recent post-incident findings, the Incident Response Plan (IRP) must explicitly address two major cybersecurity incidents:

1. **Zero-Day Vulnerability Exploitation and Unauthorized Data Exfiltration:** Exploitation of web-facing applications or secure file transfer software (such as MOVEit Transfer) by external threat actors to maintain unauthorized access and exfiltrate sensitive faculty research and financial records.
2. **Ransomware Outbreak and Endpoint Malware Execution:** Phishing-driven malware infections (such as TrickBot, Cobalt Strike, and Maze ransomware) originating from malicious attachments in emails, leading to lateral movement across facility network segments and host encryption.

1a. Recommended Detection Tools and Techniques

Detection for Incident Event 1: Zero-Day Exploitation and Data Exfiltration

- **Tool / Technique:** Security Information and Event Management (SIEM) platform integrated with Intrusion Detection Systems (IDS) and NetFlow traffic analyzers.
- **Operational Application:** The SIEM aggregates and correlates web server access logs, file access events, and network egress volume. Traffic anomaly detection techniques flag unusual outbound data transfers (such as high-volume exfiltration to unverified external IP addresses) or unexpected command executions against file transfer databases, alerting administrators to exfiltration in progress.

Detection for Incident Event 2: Ransomware Outbreak and Endpoint Malware Execution

- **Tool / Technique:** Endpoint Detection and Response (EDR) agents paired with an Email Security Gateway.

- **Operational Application:** The Email Security Gateway conducts heuristic analysis and sandboxing on compressed email attachments coming from external domains. On endpoints, EDR agents continuously monitor process behaviors, flagging suspicious process executions (such as command prompt or PowerShell scripts spawned from extracted files), volume shadow copy deletions, and rapid file encryption.

1b. Recommended Containment Actions and Alignment with Security Goals

Containment Action for Incident Event 1: Zero-Day Exploitation and Data Exfiltration

- **Containment Action:** Execute logical network isolation of the affected application server by reconfiguring edge firewall access control lists (ACLs) to block external internet egress, while revoking active session tokens and service account credentials associated with the software.

Alignment with Security Goals:

- **Aligns with Goal:** Develop policies, procedures, and practices to prevent or minimize the impact of security incidents. Isolating the application server halts active data exfiltration without taking down unimpacted enterprise networks.
- **Aligns with Goal:** Enhance the availability of research data for faculty and staff. Containing the breach at the network edge protects intellectual property and research repositories from further unauthorized exfiltration or manipulation.

Containment Action for Incident Event 2: Ransomware Outbreak and Endpoint Malware Execution

- **Containment Action:** Instantly execute host-level network isolation via EDR agent commands or physically isolate the affected facility network segment at the switch level, followed by revoking compromised user domain credentials.

Alignment with Security Goals:

- **Aligns with Goal:** Maintain business continuity through tested and validated procedures. Network segmentation stops lateral malware propagation across campus facilities, containing downtime to a localized segment.
- **Aligns with Goal:** Ensure at least 99% uptime of all student-facing systems. Preventing ransomware from reaching central databases and cloud-hosted Student Information Systems (SIS) ensures core student applications remain operational.

2. Recommended Incident Response Roles and Responsibilities

Role 1: Dedicated Incident Response Commander (IRC)

- **Responsibilities:** Leads and directs all incident response activities, oversees containment and eradication strategies, coordinates technical response teams, and serves as the primary technical decision-maker during active security incidents.
- **Business Continuity Alignment:** Establishing a single dedicated leader eliminates confusion among the four network administrators during high-stress security events. The IRC enforces structured containment strategies that prevent unnecessary total system shutdowns, maintaining operational continuity across unaffected university departments.

Role 2: Communications and Regulatory Compliance Liaison

- **Responsibilities:** Manages external notifications, coordinates mandatory regulatory reporting (such as reporting FERPA or HIPAA data breaches to authorities), communicates status updates to university executive leadership, and interfaces with law enforcement and third-party incident response consultants.
- **Business Continuity Alignment:** Offloads administrative, legal, and public relations duties from technical staff, allowing system administrators to focus exclusively on technical recovery and system restoration. Proper communication management preserves institutional reputation and maintains compliance with grant frameworks (such as NSF funding criteria), preventing business disruption from legal penalties or grant revocation.

3. Recommended Metric to Measure Incident Response Plan Effectiveness

Recommended Metric: Mean Time to Contain (MTTC)

- **Definition and Operational Value:** MTTC measures the average elapsed time from the initial detection of a security alert or incident to the successful execution of containment controls (such as host isolation, IP blocking, or account disabling). Tracking MTTC provides a quantitative measure of how rapidly the incident response team neutralizes active threats. Decreasing MTTC over time directly reflects improved automation, better staff training, and reduced business impact during security events.

4. Incident Response Plan Stakeholder Communication Strategy

To ensure execution during security events, the Incident Response Plan must be communicated across all organizational levels using a tiered strategy:

- **Executive Leadership and Board of Trustees:** Communicated through semi-annual briefing sessions and executive summary dashboards detailing high-level escalation pathways, financial decision thresholds, legal notification requirements, and risk postures.
- **Technical IT and Compliance Staff:** Communicated through detailed Standard Operating Procedures (SOPs), technical runbooks, playbooks, and quarterly hands-on tabletop exercises simulating real-world scenarios (such as zero-day exfiltration or ransomware).
- **General Faculty, Staff, and Students:** Communicated during mandatory onboarding security briefings and annual security awareness training. Focuses on incident recognition, immediate reporting channels (such as dedicated security hotlines and email reporting buttons), and initial user protocols during system disruptions.

Strategic Action Plan and Timeline

Phase 1: Governance & Response Structure (Months 1-2)

- **Action Items:** Formally establish the Incident Response Commander and Compliance Liaison roles within the IT governance framework; integrate SIEM and EDR detection controls across all campus network segments and server environments; publish the communication matrix and reporting procedures to all faculty, staff, and students.

Phase 2: Playbook Development & Testing (Months 3-4)

- **Action Items:** Draft technical runbooks for zero-day vulnerability containment and ransomware isolation; conduct initial tabletop exercises with technical administrators and executive leadership; establish MTTC tracking baselines within the incident logging ticketing system.

Phase 3: Continuous Optimization (Months 5-6)

- **Action Items:** Review MTTC metrics and refine automated EDR containment rules based on drill findings; schedule bi-annual Incident Response Plan reviews with the Legal and Compliance Office.

Direct Executive Next Steps

1. **Role Assignment:** Formally designate the Incident Response Commander and Compliance Liaison positions to establish clear leadership before future security incidents occur.
2. **Capability Procurement:** Allocate funding for SIEM and EDR software solutions to automate threat detection and reduce Mean Time to Contain (MTTC).
3. **Plan Distribution:** Distribute the updated Incident Response Plan to all department heads and schedule the first enterprise-wide ransomware tabletop exercise within 60 days.

References

- Family Educational Rights and Privacy Act (FERPA), 20 U.S.C. Section 1232g; 34 CFR Part 99.
- Health Insurance Portability and Accountability Act of 1996 (HIPAA) Security and Privacy Rules, 45 CFR Parts 160 and 164.
- National Institute of Standards and Technology. (2012). Computer Security Incident Handling Guide (NIST Special Publication 800-61, Revision 2). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2012). Conducting Risk Assessments (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce.
- National Institute of Standards and Technology. (2020). Security and Privacy Controls for Information Systems and Organizations (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce.